



China 2026

Zero-Trust Traffic Governance For Kubernetes AI Agent Sandboxes



01

PART I

Threat Model and Policy Design

Define the sandbox threat model for untrusted code and design layered traffic-control policies.

02

PART II

Implementation and Performance Validation

Transparent traffic interception, credential injection, large-scale validation, and an open-source roadmap.



AI Agents Are Moving from Chat to Action

In three years, AI evolved from conversational assistants into autonomous agents that execute code and call tools.

2023

2024 – 2025

2026

Conversational LLMs Take Off

Products such as ChatGPT and Claude popularized conversational AI without direct execution privileges.

The Agentic Shift

Claude Code, Codex CLI, Manus, and others gave AI direct code execution and made tool use standard.

Managed Sandboxes Become Core Infrastructure

Platforms such as Claude Artifacts, Alibaba Cloud Model Studio Agents, and Manus operate managed sandboxes at scale.



KubeCon



CloudNativeCon



OpenInfra
SUMMIT > ASIA



PyTorch
CONFERENCE

Untrusted Agent Code Redefines the Network Boundary

Attack path: agent code steals cloud credentials from the metadata service

- 1 User submits a prompt → the LLM generates code
- 2 The code runs `curl 100.100.100.200` (ECS metadata service)
- 3 It obtains an STS token (temporary RAM credentials)
- 4 The token calls OpenAPI → gains access to OSS, RDS, and other resources
- 5 **Lateral movement → compromises resources across the account**

How do we enforce a boundary that agent code cannot bypass?



China 2026

01 The Workload Has Changed

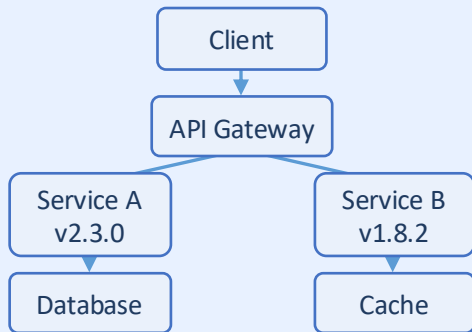
Code sandboxes are shifting from isolating applications to controlling untrusted AI-generated code



Agent Sandboxes Run Untrusted Code, Not Predictable Applications

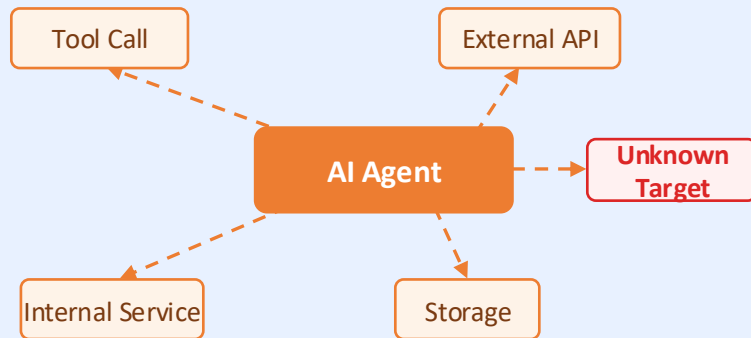
Traditional Workloads

- Application code is relatively stable
- Destinations are predictable
- Service calls can be modeled
- Changes follow release cycles



AI Agent Sandboxes

- Dynamic call graph
- Unknown destinations



Agent Workloads Defer Destinations, Identity, and Risk to Runtime

01 Untrusted Code

LLM-generated code and user scripts cannot be trusted to use the platform SDK, proxy, or gateway.



02 Dynamic Tool Calls

Destinations depend on the task, prompt, and toolchain, making them hard to enumerate before deployment.



03 Multi-Tenant Lateral Risk

Multi-tenant sandboxes share a cluster, creating risks of lateral probing and unauthorized access.



04 Short Lifecycles

Sandboxes start and stop quickly; policy must be active before the first packet, not after slow convergence.



KubeCon



CloudNativeCon



OpenInfra
SUMMIT > ASIA



PyTorch
CONFERENCE

Why Kubernetes NetworkPolicy Is Not Enough

NetworkPolicy Capability	What It Answers	Gap for Agent Workloads
Pod / Namespace selector	Which Pods the policy selects	Understands only Kubernetes labels
Ingress / Egress	Whether ingress or egress is allowed	Still limited to L3/L4 semantics
IPBlock / Port	Whether a CIDR or port is reachable	No domain or request semantics
Allowlist Model	Deny unless explicitly allowed	Policy count grows with sandbox scale

NetworkPolicy is a necessary L3/L4 baseline, but agents also need FQDN allowlists, identity semantics, and L7 request-level controls.

Agent Sandboxes Need Identity-Aware, L7 Controls

01

Domain Allowlists

Tools declare destinations by domain while IPs change dynamically.

02

HTTP Path / Header

Authorize API calls by request path and headers.

03

Token and Access-Key Control

Inject credentials at the gateway without exposing them to untrusted code.

04

Content Inspection

Filter and record LLM requests and responses for compliance.



KubeCon



CloudNativeCon

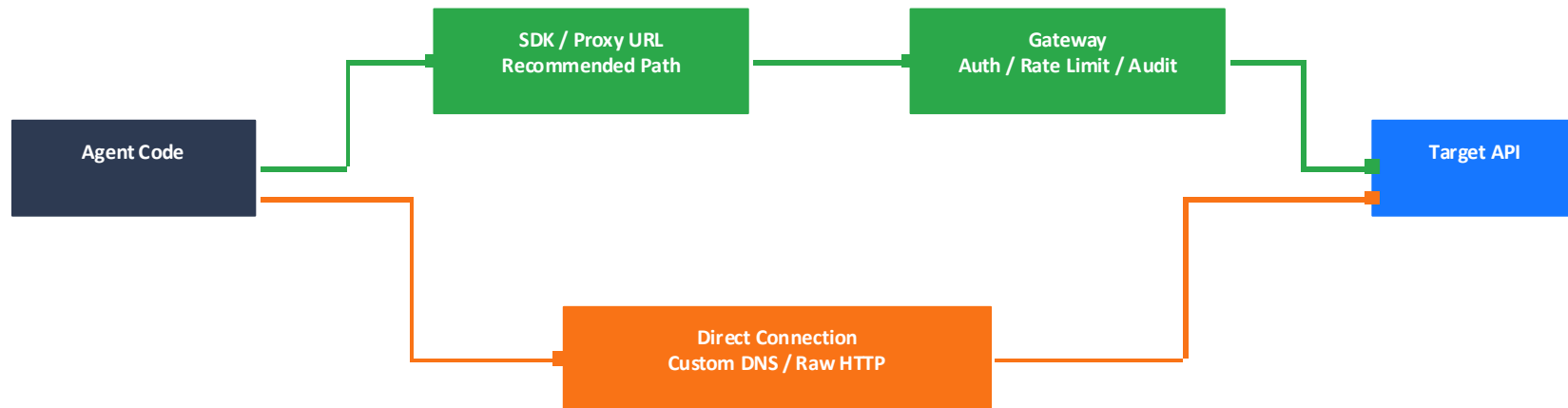


OpenInfra
SUMMIT > ASIA



PyTorch
CONFERENCE

API, LLM, and MCP Gateways Can Be Bypassed by Untrusted Code



Gateways remain valuable, but they assume the client voluntarily uses them—an assumption untrusted code does not honor.

A Strong Boundary Must Be Transparent, Preemptive, and Enforced by Default

01 Non-Cooperative

No dependency on an SDK, proxy URL, or gateway domain; bypass attempts remain controlled.

02 Transparent Interception

Enforce HTTP/HTTPS interception in the network path instead of relying on client configuration.

03 Active Before First Packet

Policy must be ready before application connections to eliminate cold-start exposure.

04 Controlled by Default

Platform baselines apply first; tenants add tool and domain allowlists only within that boundary.

A Layered Policy Model Builds the Enforceable Boundary

L4 Platform Baseline

Cluster Scope · Platform Enforced

Block metadata APIs (100.100.100.200), risky ports, and internal CIDRs. Tenant policy cannot override it.

→ Controlled by default
Platform baseline precedes tenant policy

L4 Tenant Policy

Namespace Scope · Added as Needed

Allow FQDNs, Services, CIDRs, and workloads; filter ports and protocols; refresh from DNS TTLs.

→ Non-cooperative + transparent
Enforced in-kernel with nftables/BPF

L7 Request-Level Authorization

Workload Scope · Identity + Content

HTTP method/path/header ACLs, credential injection, TLS termination, and audit webhooks.

→ Identity + L7 semantics
Control at API granularity



KubeCon



CloudNativeCon



OpenInfra
SUMMIT > ASIA



PyTorch
CONFERENCE



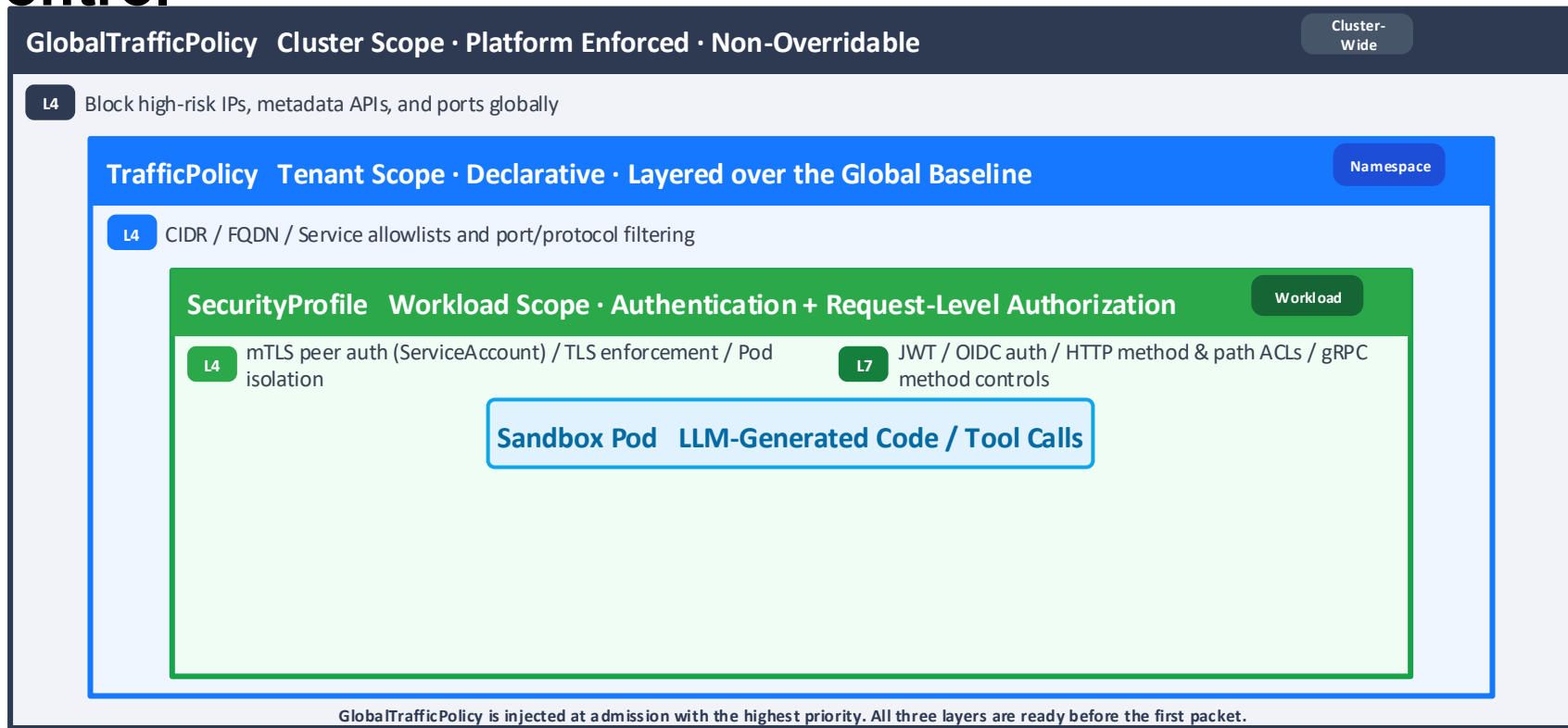
China 2026

02 Full-Stack Traffic Control for Agents

TrafficPolicy + SecurityProfile



Three Policy Layers Provide Full-Stack Sandbox Traffic Control



TrafficPolicy and SecurityProfile Split L4 and L7 Responsibilities

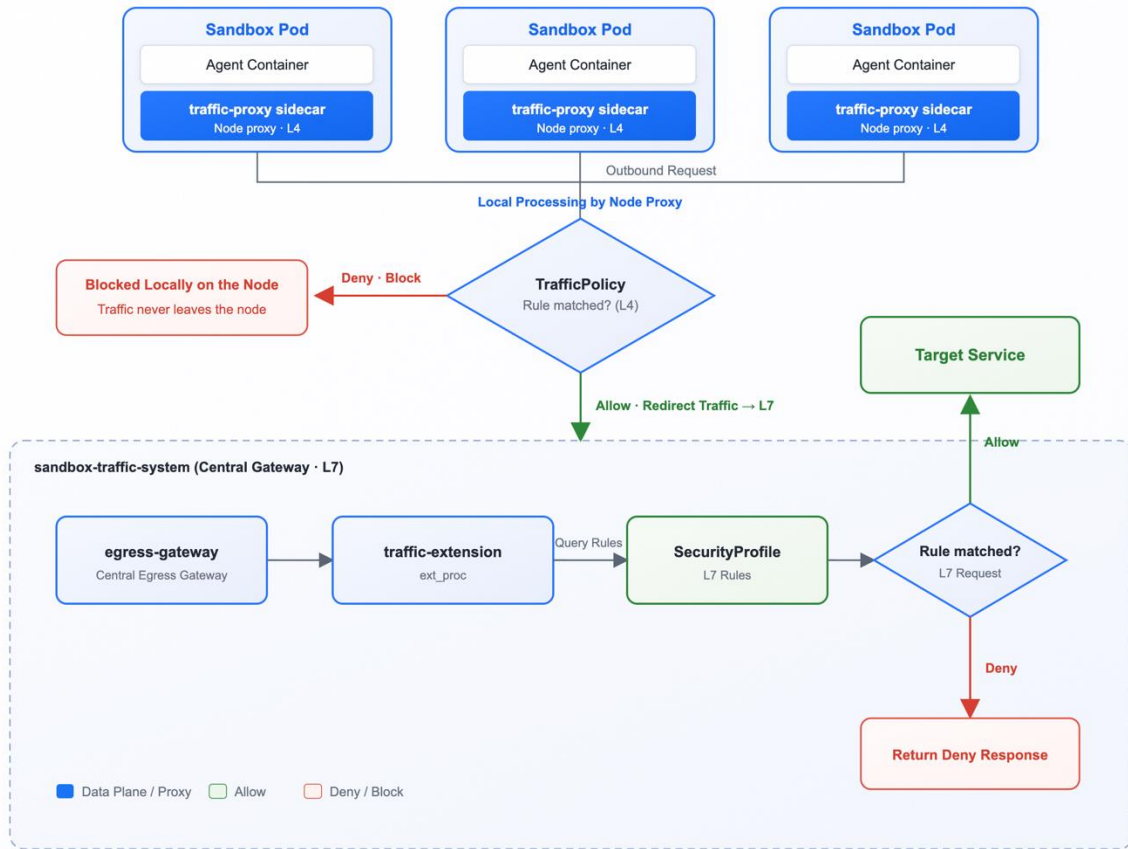
TrafficPolicy — Network Traffic Control

- Destination IP / CIDR allowlists
- Port and protocol filtering (TCP, UDP)
- Service / FQDN-based access
- Default-deny fallback

SecurityProfile — Secure Access Control

- Identity: mTLS peer authentication and TLS termination
- HTTP method/path/header ACLs
- Credential transformation for custom and OpenAPI STS tokens
- Auditing and webhook notifications

Deployment Architecture



Architecture Evolution: Why We Centralized the Gateway

FROM NODE-LOCAL TO CENTRALIZED

The first design placed a gateway on every node for short paths. Credential transformation changed the tradeoff: real access keys and tokens could not safely live on nodes or in sandboxes, so the gateway moved to a centralized tier.

OBSERVABILITY AND OPERATIONS IMPROVED TOGETHER

Distributed gateways fragmented logs, audit, rate limits, quotas, and troubleshooting. Centralization enabled one policy plane, controlled rollout, and reliable rollback.

FROM A CUSTOM GO GATEWAY TO ENVOY

The original userspace L7 gateway was written in Go, but protocol and extension maintenance became costly. We moved to Envoy and its `ext_proc` and plugin mechanisms to focus on policy.



KubeCon



CloudNativeCon



OpenInfra
SUMMIT > ASIA



PyTorch
CONFERENCE

TrafficPolicy: Core API Concepts

01 Two Scopes

TrafficPolicy is namespace-scoped for tenant configuration
GlobalTrafficPolicy is cluster-scoped for platform baselines

02 Bidirectional Rules

Configure ingress and egress independently
Support both Allow and Deny semantics

03 Four Peer Types

from/to supports CIDR, FQDN, Service, and Workload peers plus port and protocol constraints.

04 Priority-Based Merge

Lower values mean higher priority
GlobalTrafficPolicy overrides tenant rules, so tenant allowlists cannot bypass platform denies

Example: GlobalTrafficPolicy and TrafficPolicy

GlobalTrafficPolicy (Platform Baseline)

```
apiVersion: agents.kruise.io/v1alpha1
kind: GlobalTrafficPolicy
spec:
  priority: 100
  egress:
    - action: Deny
      to:
        - ipBlock: 100.100.100.200
          # Block metadata service
```

TrafficPolicy (Tenant Allowlist)

```
apiVersion: agents.kruise.io/v1alpha1
kind: TrafficPolicy
spec:
  priority: 1000
  egress:
    - action: Allow
      to:
        - service: coredns
        - workload: gateway
          namespace: sandbox-system
          selector: {...}
```

Priority 100 outranks 1000, so the platform Deny overrides the tenant Allow.



KubeCon



CloudNativeCon



OpenInfra
SUMMIT > ASIA



CONFERENCE

SecurityProfile Delivers End-to-End L7 Enforcement

C
O
R
E

Transparent Interception

TLS Termination

Make HTTPS visible to policy by intercepting TLS—transparent to applications and hard to bypass.

Multi-Dimensional Matching

RuleMatch

Match domains, paths, methods, ports, headers, and query parameters.

Ordered Rule Chain

Default Continue

Evaluate rules in order and stop only on a terminal action.

D
A
T
A

Identity Injection

IdentityInjection

Attach sandbox name, namespace, and tenant ID to egress requests.

Credential Transformation

TokenTransformation

Replace placeholder tokens with credentials from a secure provider.

Traffic Mirroring

Mirroring

Mirror matching requests asynchronously for offline analysis.

A
C
C
E
S
S

Security Inspection

SecurityCheck

Call external detectors to block prompt injection and policy violations.

Request Rate Limiting

RateLimit

Rate-limit by domain and path for cost control and fair use.

Block / Bypass / Forward

Block · Bypass · Forwarding

Block, allow directly, or forward to an internal gateway.

SecurityProfile: API Structure and Evaluation Semantics

01

Target Workloads

A selector chooses Pods; the profile applies to their HTTP/HTTPS egress.

02

Rule Structure

An ordered Rules chain; each Rule contains Match + Actions, with each action type configured at most once.

03

Match Semantics

Domains are required and support * and *.example.com. Add Paths, Methods, and Headers; Matches are ORed, fields within a Match are ANDed.

04

Evaluation Order

Evaluate Rules in order and short-circuit on the first terminal action.



KubeCon



CloudNativeCon



OpenInfra
SUMMIT > ASIA



PyTorch
CONFERENCE

SecurityProfile ACL: L7 Egress Control

Block or bypass by domain, path, method, header, and port; blocked requests return a configured response.

Block Rules + Bypass Allowlist + Default Deny

```
apiVersion: agents.kruise.io/v1alpha1
kind: SecurityProfile
metadata: {name: agent-profile, ns: default}
spec:
  selector:
    matchLabels: {agent: sample}
  rules:
    - name: deny-admin      # Block /admin prefix
      match:
        - domains: ["*"]
          paths: [{type: Prefix, value: /admin}]
          methods: [GET, POST, PUT, DELETE]
      actions:
        block: {statusCode: 403, body: '{"error": "..."}'}
    - name: allow-aliyuncs  # Allowlist: bypass
      match: [{domains: "*.aliyuncs.com"}]
      actions: {bypass: true}
    - name: deny-all       # Default deny (last)
      match: [{domains: ["*"]}]}
      actions: {block: {statusCode: 403}}
```

Match Dimensions

domains (* / *.example.com), paths (Prefix / Exact / Regex), methods, headers, queryParams, and ports

Actions

block returns a status/body (terminal); bypass allows and stops (terminal); tokenTransformation injects credentials; audit calls a webhook.

Evaluation Semantics

Fields within one match are ANDed; matches are ORed; rules run in order and stop on terminal actions; empty rules allow all.

Example: MCP Tool ACL

Allow Only Approved MCP Tool Calls

```
apiVersion: agents.kruise.io/v1alpha1
kind: SecurityProfile
metadata:
  name: mcp-whitelist
  namespace: default
spec:
  selector:
    matchLabels:
      agent: sample
  rules:
    - name: mcp-acl
      match:
        - domains: ["mcp.example.com"]
      actions:
        mcpToolPolicy:
          defaultAction: deny
          rules:
            - method: tools/call
              toolNames: ["safe"]
              action: allow
```

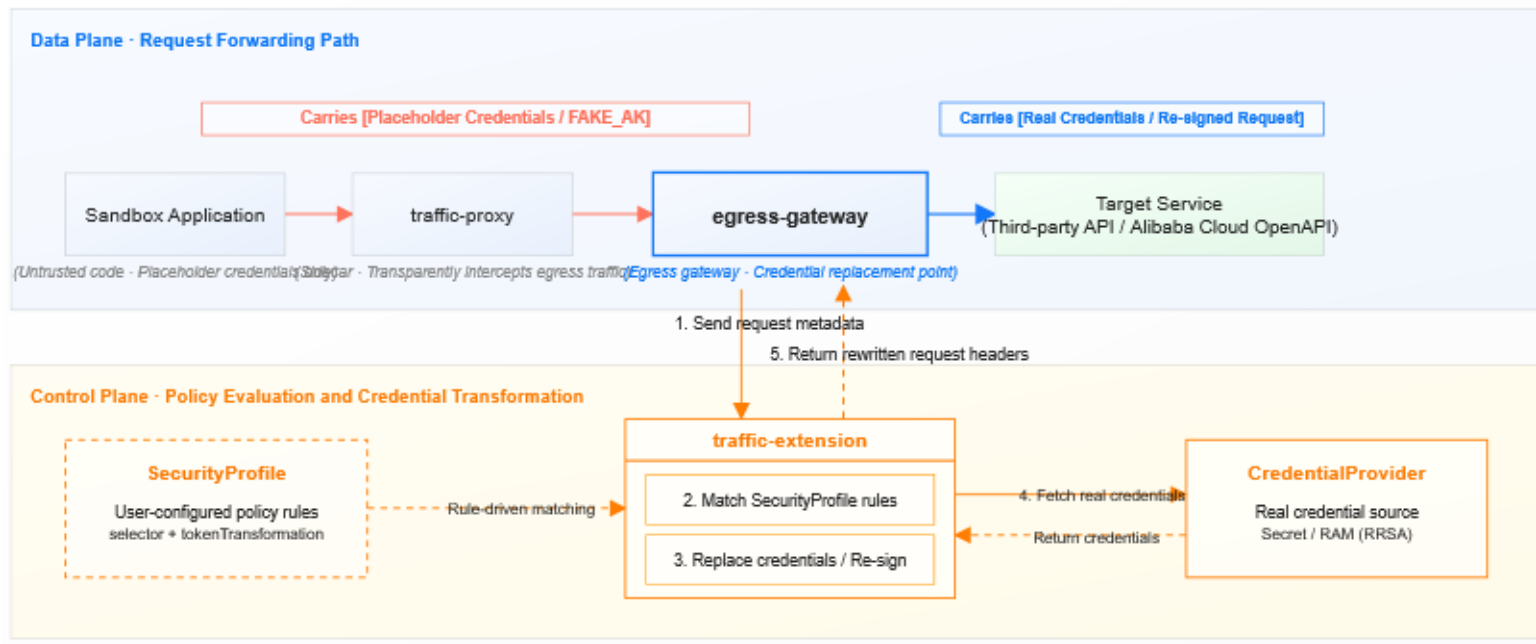
Policy Modes

Supports denylist and allowlist modes

Matches by tool name

Example: Keep Real Credentials Out of the Sandbox

Sandbox code receives only placeholders. Real API keys and cloud access keys stay on the platform and are injected by the egress gateway during forwarding—transparent to the application.



Example: SecurityProfile API-Key Injection

SecurityProfile manifest

```
apiVersion: agents.kruise.io/v1alpha1
kind: SecurityProfile
metadata:
  name: inject-llm-key
spec:
  selector:
    matchLabels:
      security.agents.kruise.io/agent-name: my-agent
  rules:
    - name: inject-openai-key
      match:
        - domains:
            - "httpbin.org" # Replace with target domain
      actions:
        tokenTransformation:
          type: ApiKey
```

credentialRef + apiKey

```
credentialRef:
  kind: CredentialProvider
  name: llm-api-key
apiKey:
  when:
    header: Authorization
    pattern: "^Bearer .+"
  targetHeader: Authorization
  valueTemplate: "Bearer {{ .Token }}"

# Result: app sends Bearer fake-token →
# egress rewrites it to real Bearer sk-****
# Real key stays in CredentialProvider (Secret)
```

Validated at Production Scale

100K+

sandboxes per cluster

500K

1,000 sandboxes × 1,000 profiles × 500 rules

200K

TrafficPolicy rules supported

25,000

rules in one TrafficPolicy

35,000 RPS

per-replica throughput (1 gateway + 1 ext, 20 SPs), P99 < 5 ms on c9i.8xlarge

0.2 ms

ext_proc overhead at 5,000 RPS; end-to-end P99 4.9 ms

<2 s

policy propagation with 20K rules

10m / 40 MB

sidecar CPU / memory with 10K rules

0

dropped requests during rolling restart and graceful drain



KubeCon



CloudNativeCon



OpenInfra
SUMMIT > ASIA



PyTorch
CONFERENCE

From Internal Implementation to Open-Source Collaboration

Four PRs Moving the Design into the Community

- #433 API proposal
Defines TrafficPolicy and SecurityProfile CRDs
- #445 Traffic Proxy
Improves traffic-proxy injection and probes
- #448 SecurityProfile
Adds CRD + controller + ext_proc with Block/Bypass
- #483 SecurityProfile CRD
Updates the CRD definition

What Works Today—and What Comes Next

- Available now
Unified API, transparent injection, and L7 filtering
- In progress
Standalone TrafficPolicy CRD, L4 data plane, and IdentityInjection
- Join the project
openkruise/agents



China 2026

